# 로그인 실패 후 일시 차단 정책의 효과와 정상 사용자 차단

사건 기반 모의실험 · 과제 10

작성자: 영찬
작성일: 2026년 10월 23일

관심 분야: 정보보안 · 로그인 보호 정책

## 초록

로그인 실패에 따른 계정 차단은 비밀번호 추측을 제한하지만 정상 접근도 막을 수 있다. 본 연구는 5회 연속 실패 후 30초 차단하는 정책과 차단 없는 정책을 사건 기반 모형으로 비교했다. 공격 간격 0.5초·2초·10초의 세 조건에서 가상 시간 600초의 요청 자료를 각각 30회 생성하고 두 정책에 동일하게 입력했다. 실제 검사된 공격 요청 수는 평균 91.81%, 71.30%, 19.90% 감소했다. 반면 정상 요청의 차단 비율은 92.17%, 73.83%, 27.00%였다. 정한 범위에서는 가설을 지지하지만, 차단 정책이 서비스 전체의 보안성과 사용성을 동시에 개선한다고 결론 내릴 수 없다. 합성 요청에 대한 모의실험이며 실제 서비스·사람·유출 비밀번호를 사용하지 않았다.


## 1. 서론

관심 분야는 정보보안 중 로그인 보호와 보안 정책 운영이다. 보안 솔루션 엔지니어를 준비하는 입장에서 차단 규칙의 효과와 사용자 영향을 수치로 비교하고자 했다. 기존 과제의 코드나 원자료를 합치지 않고 독립적으로 설계했다.

인증 지침 [1]은 온라인 추측에 대한 시도 제한을 다룬다. 실증 연구 [2]는 재사용 비밀번호를 통한 계정 추측 위험을 관측했다. 이 연구들은 제한 정책의 배경이지만, 본 모형의 '5회·30초'가 최적이라는 증거는 아니다. 새로 확인하는 것은 명시한 요청 조건에서의 검사 횟수 감소량과 정상 요청 차단량이다.

## 1.1 질문을 가설로 좁히기

검토한 질문 10개:  방화벽 규칙 수가 응답시간에 영향을 주는가  방화벽 로그가 처리량에 영향을 주는가  비밀번호 길이가 추측 성공률에 영향을 주는가  실패 후 차단이 검사 횟수를 줄이는가  차단 시간이 정상 접근에 영향을 주는가  실패 임계값이 검사 횟수에 영향을 주는가  공격 간격이 차단 효과에 영향을 주는가  계정별 제한과 IP별 제한이 다른가  정상 로그인 성공 시 실패 횟수 초기화가 결과에 영향을 주는가  다중 인증이 탈취를 줄이는가. 이 목록은 대화와 연구 설계를 정리하며 AI가 확장한 것으로, 사용자가 실제로 열 항목을 모두 토론했다는 기록은 아니다.

주제  은 사용자가 GNS3 부팅 부담과 병행 작업을 밝혀 접었다.  는 같은 가상 장비와 트래픽 환경이 필요해 접었다.  은 비밀번호 분포 가정에 성공률이 크게 좌우되어 이번 연구의 핵심으로 삼지 않았다.  ~  는 연구 범위를 넓히므로 일부는 고정 조건으로 두고  만 세 가지 사전 조건으로 반영했다.  은 추가 인증 환경 구축이 필요해 제외했다.

AI는 초기 방화벽 주제 대신 가상머신 없이 실행 가능한 로그인 모형을 제안했고, 사용자는 그 주제로 진행하는 데 동의했다. 측정 가능성에는 요청별 검사·차단 기록, 실행 가능성에는 표준 라이브러리만 쓰는 짧은 실행, 반대 결과의 의미에는 효과가 없거나 정상 사용자 피해가 큰 경우도 보고하는 방식으로 답했다. 세부 수치와 분석 설계는 AI가 정했다.

## 1.2 가설과 반증 기준

최종 가설: 동일한 로그인 요청 자료에서 5회 연속 실패 후 30초 동안 계정을 차단하면, 차단하지 않을 때보다 600초 동안 실제 검사되는 공격 요청 수가 줄어든다.

독립변수는 차단 정책 유무이며 종속변수는 차단되지 않아 정오 판정까지 진행된 공격 요청 수이다. 공격 간격은 시나리오 변수, 정상 요청 차단은 부차 지표이다. 차단된 요청은 비밀번호 검사를 수행한 것으로 세지 않는다. 각 조건에서 반복별 감소율을 계산한 뒤 산술평균한다. 사전 지정한 시나리오 중 하나라도 평균 검사 횟수가 줄지 않으면 모든 조건에서 감소한다는 해석은 지지되지 않는다. 공격 성공률은 측정 대상이 아니다.

## 2. 방법

실험 범위는 2026년 10월 23일 생성한 합성 요청이며, 각 반복의 시간 범위는 0초 이상 600초 미만이다. 실제 10분을 기다리는 실험이 아니라 가상 시간을 계산하는 프로그램이다. Python 표준 라이브러리를 사용했고 외부 사이트에 요청을 보내지 않았다. 조건을 design.json에 저장하고 첫 실행 전에 design_record.json에 설계와 코드의 SHA-256을 남겼다. 이는 로컬 선행 기록이며 외부 기관의 독립적인 사전 등록은 아니다. 최초 실행 후 설계 변경은 없었다.

별도의 파일럿 자료는 만들지 않았다. 첫 전체 실행에서 열·건수·불변조건을 확인한 뒤 결과를 모두 유지했다. 반복 수를 결과에 따라 늘리거나 불리한 반복을 삭제하지 않았다. 실행 환경과 시각은 execution_metadata.json에 기록했다.

## 2.1 실험 설계

바꾼 조건: 차단 없음, 5회 연속 실패 후 30초 계정 차단. 공격 평균 간격은 빠름 0.5초·중간 2초·느림 10초이며, 매 간격에 0.8~1.2배의 균등 변동을 적용했다.

고정 조건: 가상 시간 600초, 계정 1개, 정상 요청 20건, 정상 요청 오입력 확률 10%, 공격은 모두 잘못된 비밀번호, 임계값 5회, 차단 30초. 정상 요청 시각은 600초 구간의 균등 분포이며 요청별 정오 여부도 생성 후 고정했다. 이는 관측한 사람의 행동이 아니라 설계 가정이다.

표본: 시나리오별 30쌍, 총 90개 요청 묶음과 180회 정책 실행. 각 쌍은 동일 요청 자료를 공유한다. 시드 2026102301~2026102330을 사용한다. 정상 요청 생성에는 시드에 100000을 더한 별도 난수기를 써 시나리오 간에도 정상 요청을 같게 했다. 따라서 개별 요청을 서로 독립적인 사람의 표본으로 보지 않는다.

## 2.2 상태 처리와 기록

계정의 연속 실패 횟수는 정상 로그인 성공 시 0으로 초기화한다. 5번째 실패는 검사한 요청으로 기록한 다음 차단을 시작한다. 차단 구간은 시작 시각 이상, 해제 시각 미만이다. 차단 중 요청은 해제 시각을 연장하지 않으며 검사하지 않는다. 차단 만료 후 첫 요청에서 실패 횟수를 0으로 초기화한다. 같은 시각은 공격 요청, 정상 요청, 요청 번호 순서로 처리한다.

원자료 data/requests.csv에는 조건·반복·시드·요청 번호·가상 시각·행위자·정답 여부를 보관한다. results/events.csv에는 두 정책 각각의 판단·실패 횟수·해제 시각을 보관한다. results/runs.csv는 반복별 건수이며 summary.json은 요약이다. 정상 요청 차단 비율은 차단된 정상 요청/제출된 정상 요청이다. 정답 정상 요청 차단도 별도로 기록했다.

## 3. 결과

세 조건 모두 평균 공격 검사 횟수가 감소하여 지정한 범위에서 가설을 지지했다. 감소율은 각 반복의 비율을 평균한 값으로, 전체 평균 건수로 계산한 비율과 소수점에서 다를 수 있다.

fast: 공격 검사 1199.07 → 98.17건/반복, 감소율 91.81% (반복 범위 91.25~92.17%). 정상 차단 553/600건 (92.17%). 정답 정상 요청 차단 497/542건. 정상 성공 542 → 45건.

medium: 공격 검사 299.27 → 85.87건/반복, 감소율 71.30% (반복 범위 68.01~73.24%). 정상 차단 443/600건 (73.83%). 정답 정상 요청 차단 400/542건. 정상 성공 542 → 142건.

slow: 공격 검사 59.43 → 47.60건/반복, 감소율 19.90% (반복 범위 8.33~28.33%). 정상 차단 162/600건 (27.00%). 정답 정상 요청 차단 143/542건. 정상 성공 542 → 399건.

정상 요청은 각 시나리오에서 30회×20건=600건이다. 세 시나리오가 같은 정상 자료를 사용하므로 서로 다른 1,800명의 행동이 아니다. 정상 비밀번호가 맞은 542건 중 빠름 조건에서 497건이 차단됐다. 이는 단순한 오입력 거절이 아니라 계정 잠금에 의한 접근 거절이다. 세 조건의 90개 쌍을 모두 보고했으며 개별 결과는 runs.csv에 있다.

| 공격 간격 | 검사 감소율 | 정상 차단/전체 |
|---|---|---|
| fast | 91.81% | 553/600 |
| medium | 71.30% | 443/600 |
| slow | 19.90% | 162/600 |

## 4. 논의

가설대로 나온 부분은 모든 사전 지정 시나리오의 검사 횟수 감소이다. 그러나 예상 가능한 반대 측면인 정상 접근 손실도 크게 나타났다. 정상 접근을 유지하면서 공격만 막는다는 주장은 이 자료로 지지되지 않는다. 차단 자체가 검사를 건너뛰도록 구현되어 있어 감소 방향은 모형상 상당 부분 예상된다. 연구의 가치는 새로운 방어 원리의 발견보다 조건별 감소 폭과 서비스 접근 손실을 함께 드러낸 데 있다.

효과 크기가 다른 이유로 공격 간격, 정상 성공에 따른 실패 초기화, 유한한 관찰 구간의 끝부분을 검토했다. 세 조건에서 정상 입력을 동일하게 유지했으므로 공격 간격 차이와 효과 차이의 연결은 관측 가능하다. 실패 초기화와 관찰 구간 효과는 코드에 존재하지만 각각을 제거한 추가 실험은 하지 않아 독립적인 원인으로 확정하지 않는다. 정상 차단은 공격과 정상 요청이 한 계정의 잠금을 공유하기 때문에 발생한다. 본 모형은 요청 생성 자체를 멈추지 않으므로 공격 네트워크 트래픽이 줄었다고 해석하면 안 된다.

가설은 수정하지 않았다. 대신 결론의 범위를 '비밀번호 검사 횟수 감소'로 유지하고 '공격 성공 방지'나 '좋은 정책'이라는 확대 해석을 제외했다. 5회·30초를 실제 서비스의 권장값으로 제시하지 않는다.

## 4.1 작성자의 판단과 후속 검증

작성자는 사전 접근 규칙과 사후 이상 징후 분석을 상호 보완적으로 운영하는 방안을 제안했다. 사전 규칙을 통과하지 못한 요청은 인입 단계에서 차단하고, 통과한 요청도 이후 행위를 계속 분석하여 이상 징후가 확인되면 방화벽 차단으로 연결하는 방식이다. 작성자는 이 방식이 가장 효과적일 것이라고 판단했다. 다만 본 연구는 이 결합 정책의 효과나 실시간 탐지 정확도를 비교하지 않았으므로, 가장 효과적이라는 평가는 검증된 결론이 아니라 작성자의 후속 적용 제안이다. 정상 접근 차단이 크게 나타난 결과를 고려해, 탐지 오류·정상 요청 차단율·탐지에서 차단까지의 시간·차단 해제 절차도 후속 실험에서 평가할 필요가 있다.

작성자가 언급한 checklist.md는 사전 규칙이라는 개념을 설명한 표현이다. 현재 패키지의 checklist.md는 과제 기준 대응 문서이고, results/summary.json은 모의실험 전체의 조건별 집계다. 두 파일은 실제 요청 허용 여부를 판정하거나 개체별 이상 행동을 실시간 탐지하는 실행 모듈이 아니다. 제안 구현에는 별도의 기계 판독 가능한 접근 정책, 개체별 사건 기록, 탐지 로직과 방화벽 연동이 필요하며 이번 연구에는 구현하지 않았다.

## 4.2 한계

실제 인증 서버, 해시 연산, CPU 사용량, 지연, 네트워크, 사람의 재시도 행동을 측정하지 않았다. 공격은 항상 실패하도록 정했으므로 비밀번호 탈취 확률이나 공격 성공률을 계산할 수 없다. 단일 계정에 지속 공격하는 가정은 계정 잠금의 부작용을 크게 드러내지만 현실의 다중 계정·IP 우회·분산 공격을 대표하지 않는다. 30회 반복은 가정한 입력 변동을 보여줄 뿐 현실 모집단에 대한 통계적 추론을 보장하지 않는다. 유의확률이나 현실 효과의 신뢰구간은 제시하지 않는다. 과제의 계획시간 8~10시간을 실제 수행시간으로 주장하지 않는다.

## 4.3 결론

동일한 합성 요청 자료를 두 정책에 적용했을 때 5회 실패 후 30초 차단 정책은 세 공격 간격 모두에서 실제 검사된 공격 요청 수를 줄였다. 평균 감소율은 빠름 91.81%, 중간 71.30%, 느림 19.90%였다. 동시에 정상 요청도 각각 92.17%, 73.83%, 27.00% 차단됐다. 따라서 이 모의실험은 검사 기회 제한 효과를 지지하지만, 정상 사용자 영향을 무시한 정책 적용을 뒷받침하지 않는다. 실제 환경에 적용하기 전에는 정상 접근 손실과 계정·IP 범위, 복구 방법을 별도로 검증할 필요가 있다. 이는 후속 검증 과제이며 본 연구에서 이미 효과가 확인된 조치는 아니다.

## 참고문헌

[1] Temoshok, D., Fenton, J., Choong, Y.-Y., Lefkovitz, N., Regenscheid, A., Galluzzo, R., & Richer, J. (2025). Digital Identity Guidelines: Authentication and Authenticator Management. NIST SP 800-63B-4. https://csrc.nist.gov/pubs/sp/800/63/b/4/final

가설 연결: 온라인 추측에 대한 시도 제한을 연구할 정책적 배경이다. 이 문헌이 본 실험의 5회·30초 값을 검증했다는 뜻은 아니다.

[2] Nisenoff, A., Golla, M., Wei, M., Hainline, J., Szymanek, H., Braun, A., Hildebrandt, A., Christensen, B., Langenberg, D., & Ur, B. (2023). A Two-Decade Retrospective Analysis of a University's Vulnerability to Attacks Exploiting Reused Passwords. 32nd USENIX Security Symposium, 5127-5144. https://www.usenix.org/conference/usenixsecurity23/presentation/nisenoff-retrospective

가설 연결: 대학 계정을 대상으로 한 데이터 기반 분석으로 비밀번호 추측 위험의 현실적 배경을 제공한다. 본 정책의 효과를 직접 증명하는 문헌은 아니다.

확인 방법: 2026-10-23에 NIST 공식 발행 페이지에서 제목·저자·2025년 발행일을 확인하고 공식 HTML의 시도 제한 내용을 확인했다. USENIX 공식 학회 페이지에서 전체 저자·연도·쪽수·초록의 데이터 기반 분석 여부를 확인했다. 두 번째 문헌은 초록까지 확인했으며 본문 전체를 정독했다고 주장하지 않는다.

제외 문헌: Alsaleh 등의 Revisiting Defenses against Large-Scale Online Password Guessing Attacks는 검색 후보였으나 대학 저장소 상세 페이지 열기가 실패해 이번 참고문헌에서 제외했다. NIST 구판 SP 800-63B와 초안은 최신 확정판으로 대체했다. 검색 중 나온 상업 블로그와 SNS는 근거로 채택하지 않았다. 공개 데이터는 다운로드하지 않았다. 원자료는 자체 생성한 합성 자료이며 참고문헌 열람일과 생성일을 구분한다.

## 부록 A. 재현 방법

ZIP을 새 폴더에 풀고 ALEPH_10 폴더에서 python run.py --replay 를 실행하면 저장된 원자료로 결과를 다시 계산한다. Windows에서 python 명령이 없으면 py -3 run.py --replay 를 사용한다. 새 입력까지 재생성하려면 python run.py 를 실행한다. Python 3.9 이상과 표준 라이브러리만 필요하다. PDF는 이미 포함되어 있어 다시 만들 필요가 없다.

짧은 확인: python verify.py 를 실행하면 원자료 건수, 정책 실행 건수, 합계 일치, 반복별 결과 재생성과 원본 해시를 확인한다. verify.py는 임시 폴더에서 재실행하므로 보관한 결과를 덮어쓰지 않는다. 결과를 보관한 뒤 입력을 바꾸려면 원본 ZIP을 별도로 유지한다.

표본과 원자료 건수는 data_counts.json, 파일 무결성은 SHA256SUMS.json에 있다. 외부 데이터나 API 키가 없어 오프라인 재현이 가능하다. 제출은 ZIP 파일로 하며 배포·저장소 URL은 요구하지 않는다. 참고문헌 링크는 공개 원문 근거이며 이번 확인에서는 로그인 없이 열렸지만 실제 새 시크릿 창 테스트를 수행한 것은 아니다.

## 부록 B. AI와 나의 판단 3줄

1. AI에게 맡긴 일: 후보 정리, 실험 설계와 코드 작성·실행, 출처 확인, 원자료 요약, 논문 작성이다.

2. 내가 판단한 일: 가상머신 없이 가능한 로그인 차단 모의실험을 선택하고, 사전 접근 규칙과 사후 이상 탐지를 연계하는 상호 보완 정책이 필요하다고 판단했다.

3. 나의 제안: 사전 규칙을 통과하지 못한 접근은 인입 단계에서 막고, 통과 후에도 이상 징후를 감지해 방화벽 차단으로 연결하되, 이 결합 정책의 실제 효과는 후속 실험으로 확인한다.